



Politécnico
Internacional

ASEGURAMIENTO DE INFRAESTRUCTURA DE REDES Y SISTEMAS

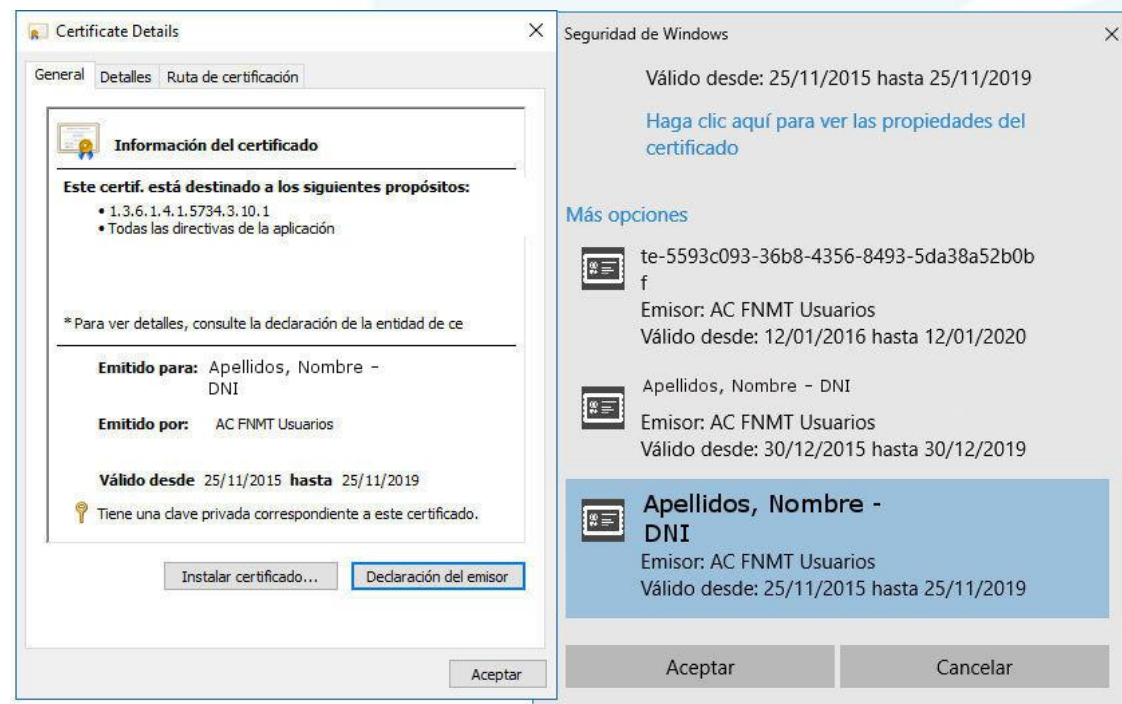
**«Los amateurs hackean sistemas,
los profesionales hackean
personas».- Bruce Shneier.**

- ☐ Certificados Digitales
- ☐ Certificados de Atributos
- ☐ RFC 32821
- ☐ PKI (Public Key Infrastructure).

CERTIFICADOS DIGITALES

Un certificado digital es un **documento electrónico** que vincula criptográficamente una **clave pública** con la identidad de su propietario, garantizando la autenticidad, integridad y no repudio en las comunicaciones digitales.

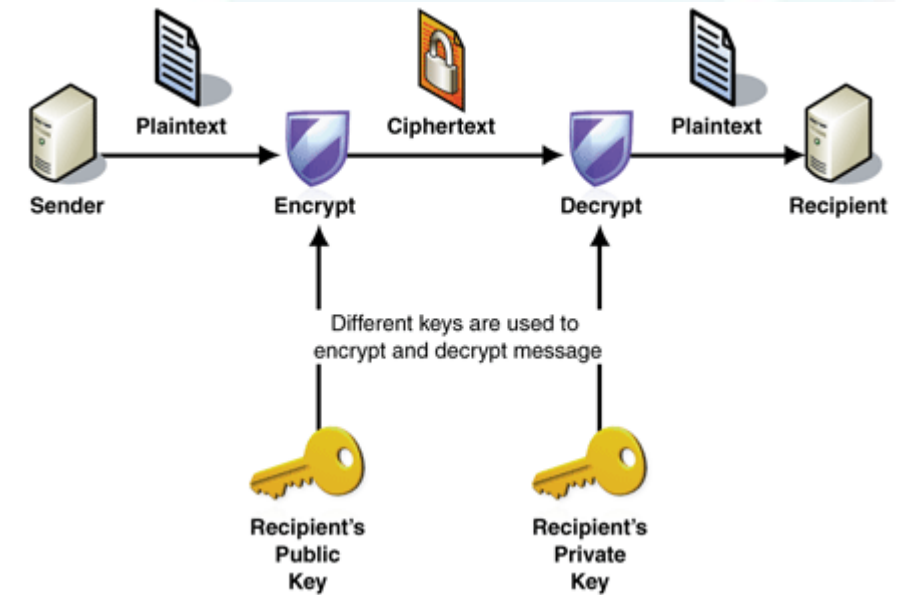
Se basa en el estándar **ITU-T X.509 (actualmente versión 3)** y es emitido por una Autoridad de Certificación (CA), que firma el certificado utilizando su propia clave privada. El certificado se utiliza en protocolos de seguridad como TLS/SSL, IPsec, S/MIME o para firma de código.



CERTIFICADOS DIGITALES

Estructura típica de un certificado **X.509 v3**:

- Versión: indica el formato (v1, v2, v3).
- Número de serie: identificador único asignado por la CA.
- Algoritmo de firma: ejemplo sha256WithRSAEncryption.
- Emisor (Issuer): datos de la CA emisora.
- Periodo de validez: fecha de inicio y expiración.
- Sujeto (Subject): datos del titular (nombre, organización, país).
- Clave pública del sujeto.
- Extensiones: campos como KeyUsage, SubjectAltName, ExtendedKeyUsage.
- Firma digital de la CA.



CERTIFICADOS DIGITALES

Normativa y Estándares:

- X.509 para estructura y formato.
- RFC 5280 para perfiles de certificados y CRLs.
- Criptografía asimétrica (RSA, ECC, EdDSA).

Seguridad y Propósito:

- Autenticación de identidad.
- Cifrado de canal de comunicación.
- Validación de integridad de datos.
- No repudio en transacciones electrónicas.



www.ssl.com
Issued by: SSL.com EV SSL Intermediate CA RSA R3
Expires: Saturday, April 17, 2021 at 5:15:06 PM Central Daylight Time
✔ This certificate is valid

▼ Details

Subject Name	
Country or Region	US
State/Province	Texas
Locality	Houston
Organization	SSL Corp
Serial Number	NV20081614243
Common Name	www.ssl.com
Postal Code	77098
Business Category	Private Organization
Street Address	3100 Richmond Ave
Inc. State/Province	Nevada
Inc. Country/Region	US

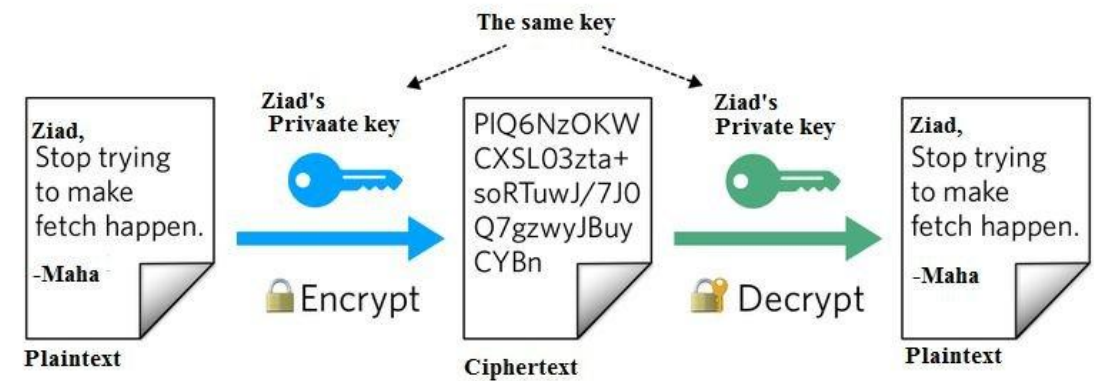
CERTIFICADOS DIGITALES

Ciclo de vida:

- Generación del par de claves (privada y pública).
- Creación de CSR (Certificate Signing Request).
- Validación por la CA.
- Emisión y distribución.
- Renovación o revocación (CRL/OCSP).

Tipos de Certificados:

- Servidor SSL/TLS: para cifrado web.
- Cliente: autenticación de usuario.
- Firma de código: garantizar integridad de software.
- Correo seguro (S/MIME): cifrado y firma de emails.



CERTIFICADOS DIGITALES: EJEMPLO TECNICO

```
# 1. Generar clave privada de 2048 bits
openssl genrsa -out servidor.key 2048
```

```
# 2. Generar CSR (Solicitud de Firma de Certificado)
openssl req -new -key servidor.key -out servidor.csr \
-subj
"/C=CO/ST=Cundinamarca/L=Soacha/O=Instituto/OU=Seguridad/CN
=www.ejemplo.com"
```

```
# 3. Generar certificado X.509 v3 válido por 365 días
openssl x509 -req -days 365 -in servidor.csr -signkey servidor.key -  
out servidor.crt
```

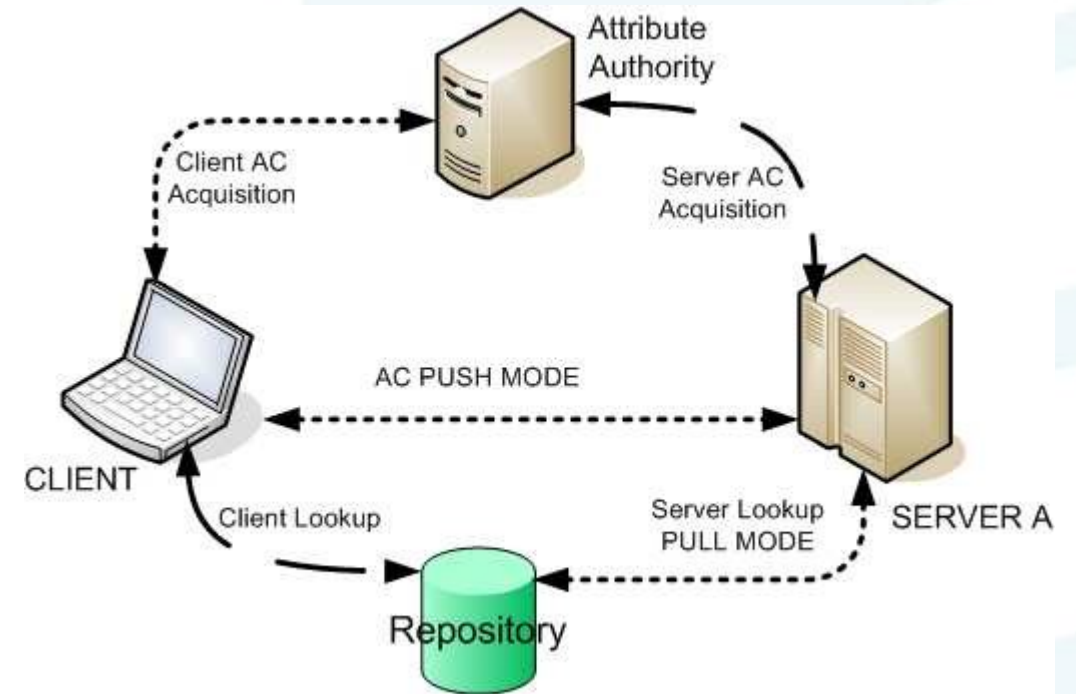
4. Ver detalles del certificado

[illegible]

CERTIFICADOS ATRIBUTOS

Un **certificado de atributos (Attribute Certificate, AC)** es un documento electrónico, definido en el estándar ITU-T X.509 y especificado en el RFC 5755, que asocia un conjunto de atributos o privilegios a un sujeto, sin contener una clave pública.

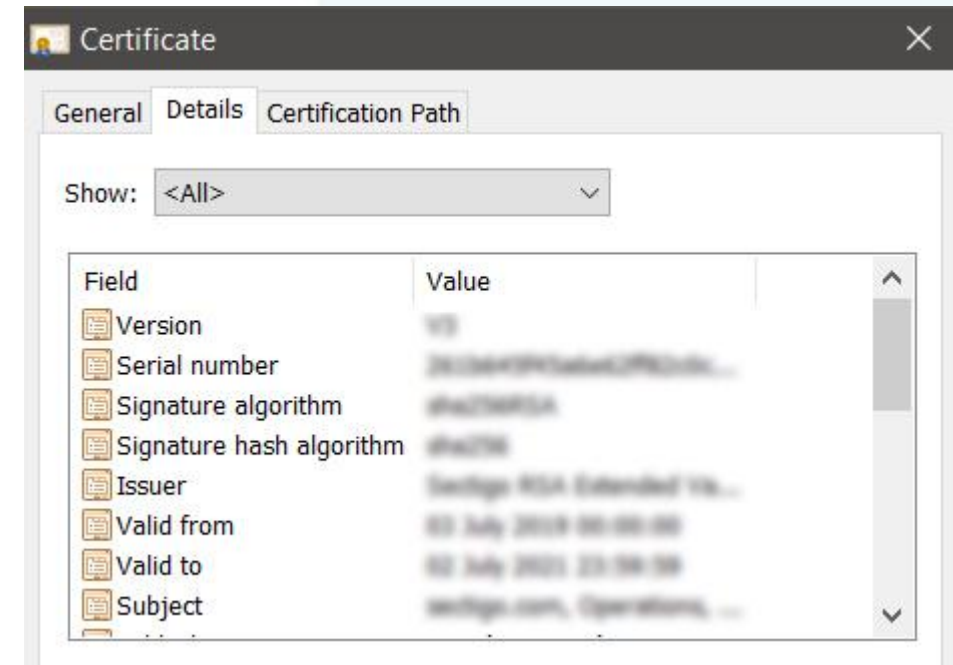
A diferencia de los certificados digitales tradicionales, que vinculan una identidad con una clave pública, el AC vincula una identidad existente (**normalmente referenciada por un certificado digital X.509**) con información adicional, como roles, permisos o restricciones.



CERTIFICADOS ATRIBUTOS

Estructura principal de un AC:

- **Versión:** versión del formato (actualmente v2).
- **Holder:** referencia al certificado digital o identidad del titular.
- **Issuer:** identidad de la Autoridad de Atributos (AA) que emite el AC.
- **Serial Number:** identificador único.
- **Atributos:** roles, permisos, políticas de acceso.
- **Periodo de Validez:** inicio y expiración del certificado.
- **Extensiones:** campos adicionales definidos por políticas.
- **Firma Digital de la AA.**



CERTIFICADOS ATRIBUTOS

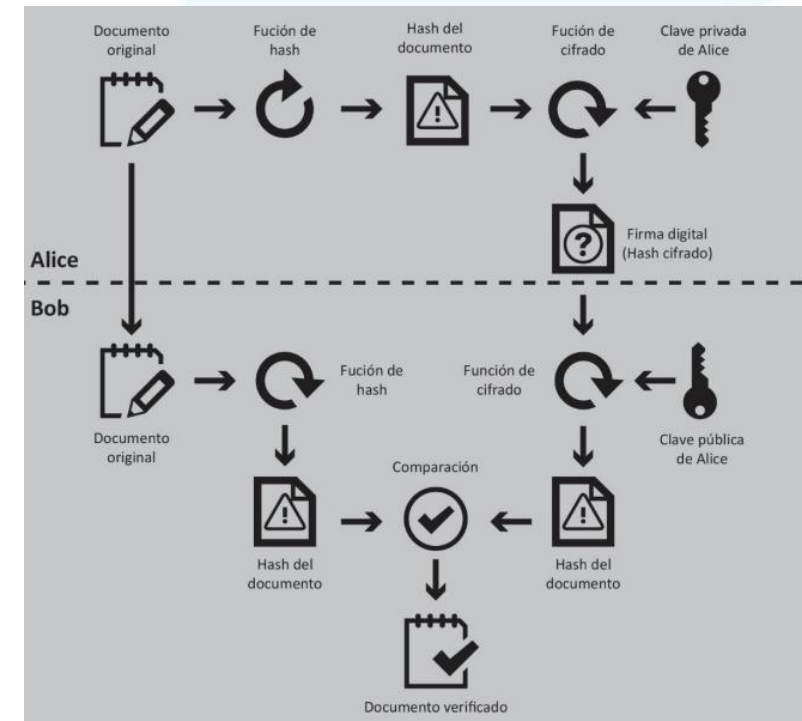
Características Técnicas

Normativa y Estándares:

- X.509 Attribute Certificates.
- RFC 5755 (formato y validación).
- RFC 3281 (perfil para uso en Internet).
- RFC 3821 (uso con S/MIME para mensajes seguros).

Seguridad y Propósito:

- Control de acceso basado en roles (RBAC).
- Delegación de privilegios sin emitir un nuevo certificado de identidad.
- Separación de funciones: una CA emite certificados de identidad, una AA emite certificados de atributos.



CERTIFICADOS ATRIBUTOS

Características Técnicas

Ventajas:

- Permite actualizar permisos sin reemplazar certificados de identidad.
- Puede expirar rápidamente (control granular de tiempo de validez).
- Facilita integración con sistemas de autorización centralizados.

Aplicaciones típicas:

- Autenticación y autorización en sistemas corporativos.
- Control de acceso en VPNs y redes militares.
- Firmas digitales con atributos especiales para roles (por ejemplo, "Aprobador Financiero").



CERTIFICADOS ATRIBUTOS: EJEMPLO

Generar un Certificado de Atributos con OpenSSL, referenciando un certificado de identidad existente:

1. Crear archivo con atributos en formato ASN.1 (atributos de ejemplo)

```
cat > atributos.cnf <<EOF  
[ atributos ]  
role=STRING:Administrador  
permissions=STRING:AccesoTotal  
EOF
```

2. Generar el certificado de atributos (simplificado para pruebas)

```
openssl ca -extensions atributos -in usuario.csr -out atributos.crt \  
-cert autoridad_atributos.crt -keyfile autoridad_atributos.key
```



Modo de Uso de Certificados de Atributos (Perfil RFC 3281)

El perfil **RFC 3281** (y su versión más reciente, RFC 5755) establece cómo los certificados de atributos **X.509 (AC)** se deben usar en protocolos de Internet.

Su objetivo principal es definir un marco interoperable para aplicaciones que requieren autorización basada en atributos en servicios como correo electrónico (S/MIME), IPSec y seguridad web.



Modo de Uso de Certificados de Atributos (Perfil RFC 3281)

Características Técnicas del Perfil

Durabilidad y Delegación

- Separación de funciones entre certificado de identidad (emitido por CA) y certificado de atributos (emitido por AA), lo que permite actualizar roles sin cambiar la identidad.
- AC puede tener una validez corta y ajustarse dinámicamente sin afectar el certificado de identidad.

Flexibilidad Multiplataforma

- Compatible con aplicaciones de correo seguro (S/MIME), VPN basadas en IPSec y control de acceso en web.

Estructura Específica

- AC incluye campos como Holder, Issuer, Serial Number, Validity Period, Attributes, firma digital, y opcionalmente extensiones.



PKI (Public Key Infrastructure)

La **PKI (Infraestructura de Clave Pública)** es un conjunto de políticas, procedimientos, roles, hardware, software y estándares criptográficos que permiten la gestión segura de claves y certificados digitales.

Su función principal es **garantizar los principios de confidencialidad, integridad, autenticación y no repudio** en las comunicaciones electrónicas mediante el uso de criptografía asimétrica.

En una PKI, se utilizan pares de claves (pública y privada) y certificados digitales X.509 emitidos por Autoridades de Certificación (CA) para validar la identidad de usuarios, sistemas o dispositivos.



PKI (Public Key Infrastructure)

Características

Estructura jerárquica o distribuida:

- Puede implementar un modelo jerárquico (Root CA → Sub CA) o un modelo en malla (cross-certification).
- Permite delegar confianza de una CA raíz a múltiples CA subordinadas.

Gestión de Ciclo de Vida de Certificados:

- Emisión, distribución, renovación, revocación y expiración de certificados.
- Uso de CRL (Certificate Revocation List) o OCSP (Online Certificate Status Protocol).



PKI (Public Key Infrastructure)

Características

Soporte para Estándares Internacionales:

- Basada principalmente en X.509 (formato de certificados).
- Compatible con protocolos como TLS/SSL, S/MIME, IPsec, entre otros.

Integración con Múltiples Aplicaciones:

- Firmas digitales, autenticación de usuarios, VPNs, correo seguro, y cifrado de datos.

Seguridad de Claves Privadas:

- Uso de módulos HSM (Hardware Security Module) para proteger las claves privadas de la CA.



PKI (Public Key Infrastructure) : Ejemplo de Implementación

Supongamos que una empresa colombiana de pagos en línea implementa una PKI interna para asegurar transacciones entre clientes, servidores y pasarelas de pago:

Root CA:

- Instalado en un servidor aislado (air-gapped) para emitir certificados solo a Sub CA.

Subordinate CA (Sub CA):

- Emite certificados SSL/TLS para los servidores de la pasarela.
- Emite certificados para el cifrado de correos internos (S/MIME).



PKI (Public Key Infrastructure) : Ejemplo de Implementación

Registro de Usuarios (RA - Registration Authority):

- Verifica la identidad de los empleados antes de emitirles un certificado personal.

Uso en Transacciones:

- Cliente se conecta al servidor con HTTPS.
- El servidor presenta su certificado firmado por la Sub CA.
- El cliente valida la cadena de confianza hasta la Root CA.
- Todo el tráfico se cifra y autentica, previniendo ataques MITM (Man-in-the-Middle).



CONCLUSIONES